

SkillUp

In collaboration with
IBM SkillsBuild



SkillUp Online In collaboration with IBM SkillsBuild Presents

10 Semanas Certificado Profesional en Ciberseguridad | 1Q 2026



Agenda de la 4ta sesión técnica

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

- Pasos en la respuesta a incidentes (Detección, Contención, Erradicación, Recuperación)
- Uso de SIEM (Gestión de Información y Eventos de Seguridad) para el monitoreo
- Práctica: Simulación de un ciberataque (por ejemplo, ataque de fuerza bruta) y respuesta al mismo
- Creación de un informe de respuesta a incidentes

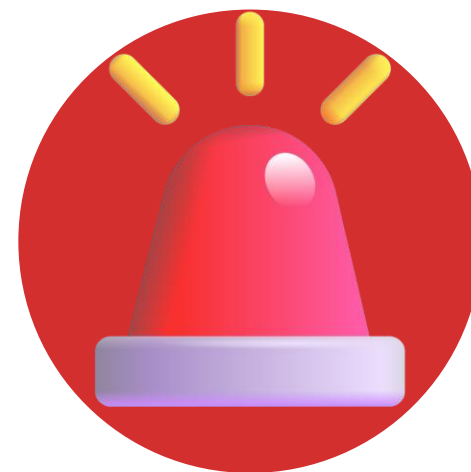




01

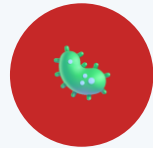
PASOS EN LA RESPUESTA A INCIDENTES

DETECCIÓN, CONTENCIÓN, ERRADICACIÓN, RECUPERACIÓN



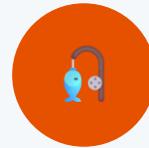
¿QUÉ ES UN INCIDENTE DE SEGURIDAD?

Un incidente de seguridad es cualquier evento que amenaza la confidencialidad, integridad o disponibilidad de los activos de información de una organización, incluyendo accesos no autorizados, malware, filtraciones de datos o ataques que interrumpen operaciones.



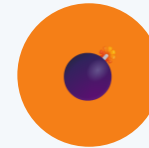
Malware

Virus, ransomware, troyanos, spyware que infectan sistemas



Phishing

Suplantación de identidad para robar credenciales o instalar malware



DoS / DDoS

Saturación de servicios para hacerlos inaccesibles



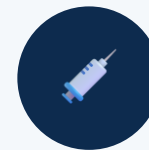
Insider

Empleados o ex-empleados con acceso malicioso o negligente



Data Breach

Acceso o exfiltración no autorizada de datos confidenciales



Inyección SQL

Manipulación de bases de datos mediante consultas maliciosas

IMPACTO DE UN INCIDENTE- TRIADA CID



Confidencialidad

Garantiza que la información solo sea accesible por personas autorizadas. Un incidente la compromete cuando datos sensibles son robados o expuestos.

📌 Caso real:

Filtración de datos de clientes del Banco Santander (2024): 30M+ registros expuestos.



Integridad

Asegura que los datos no han sido alterados de forma no autorizada. Un incidente la compromete cuando un atacante modifica archivos, logs o registros.

📌 Caso real:

Ataque a SolarWinds (2020): código malicioso insertado en actualizaciones legítimas.



Disponibilidad

Garantiza que los sistemas estén accesibles cuando se necesiten. Un incidente la compromete cuando servicios quedan inoperativos.

📌 Caso real:

Ransomware WannaCry (2017): hospitales y empresas dejaron de operar durante días.



*" Solo hay dos tipos de
empresas: aquellas que han
sido hackeadas y aquellas que
lo serán "*

Robert Mueller, exdirector del FBI

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES



REPORT

La respuesta a incidentes (IR)

comprende el conjunto de acciones que realiza una organización para

- Preparar
- Exponer
- Detener los ciberataques
- También incluye la reparación de cualquier daño que provenga del ataque
- Y la recopilación de datos que puedan ayudar a prevenir un ataque similar en el futuro

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

¿Cómo comienzan las organizaciones a recopilar toda la información necesaria para un plan integral de respuesta a incidentes?



Con un marco de respuesta a incidentes

- Proporciona una estructura para respaldar las operaciones de respuesta a incidentes
- Proporciona orientación sobre lo que se debe hacer, pero no sobre cómo se hace
- Es lo suficientemente flexible como para permitir que las organizaciones agreguen o eliminen elementos según sea necesario para satisfacer sus necesidades

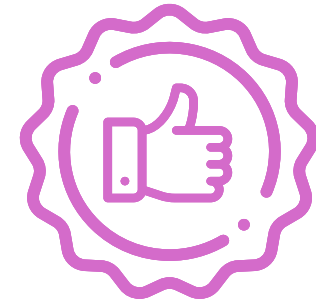
RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

Marco de respuesta a incidentes

El NIST es el marco más popular y estándar

El NIST (**National Institute of Standards and Technology**) es una agencia operada por el Departamento de Comercio de Estados Unidos, que proporciona estándares y recomendaciones para muchos sectores tecnológicos.

El NIST desarrolló la **Guía** de manejo de incidentes de seguridad informática como marco de respuesta a incidentes.



RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

FASES DE RESPUESTA A INCIDENTES (IR)

A continuación, el equipo



evalúa la gravedad de un
ataque



desarrolla una **estrategia** de
priorización de amenazas



investiga y **mitiga** el
ataque

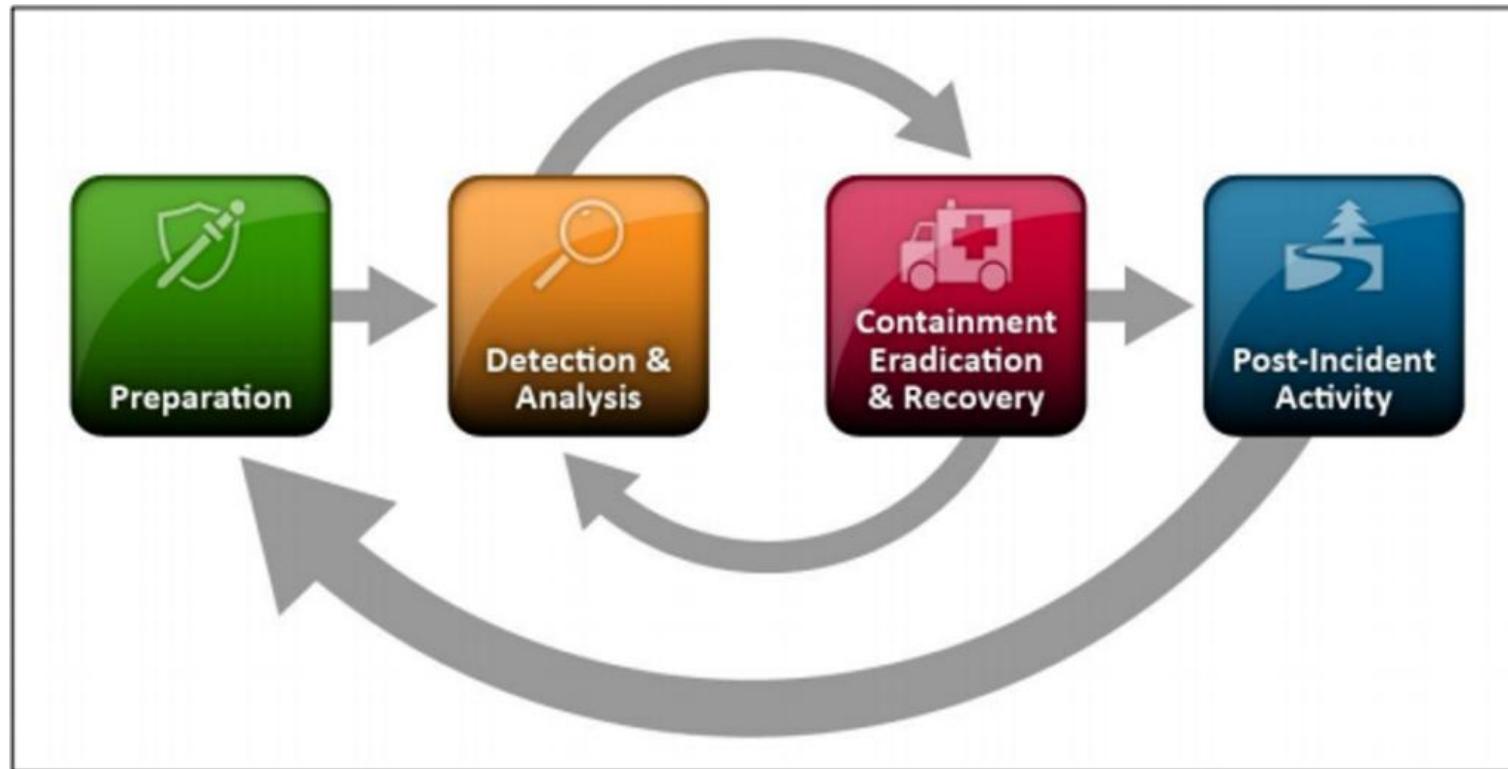
restaura las
operaciones



Y toma **medidas preventivas**
para reducir la posibilidad de
que se repita.

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

FASES DE RESPUESTA A INCIDENTES (IR)





PASO 1 — PREPARACIÓN

1
Prep.

2
Ident.

3
Conten.

4
Errad.

5
Recup.

6
Post-IR

 La preparación es la fase más importante. Ocurre ANTES de cualquier incidente y determina cuán efectivamente podrá responder una organización cuando ocurra uno.



Plan de Respuesta (IRP)

Documento formal que define procesos, responsabilidades y procedimientos de escalado ante incidentes.



Equipo CSIRT definido

Computer Security Incident Response Team con roles claros: líder, analistas, comunicaciones, legal.



Herramientas instaladas

SIEM, EDR, IDS/IPS, escáneres de vulnerabilidades y sistemas de ticketing configurados.



Capacitación del equipo

Simulacros regulares (tabletop exercises), formación en herramientas y conocimiento de amenazas actuales.



Canales de comunicación

Contactos de proveedores, autoridades (INCIBE, CERT), clientes y cadena de mando definidos.



Backups y resiliencia

Copias de seguridad probadas, planes de continuidad de negocio y entornos de recuperación disponibles.

PASO 2 — IDENTIFICACIÓN Y DETECCIÓN

1
Prep.

2
Ident.

3
Conten.

4
Errad.

5
Recup.

6
Post-IR



Detectar si lo que ocurre es realmente un incidente. Analizar alertas, logs y comportamientos anómalos para confirmar y clasificar la amenaza según su severidad.

Fuentes de detección:



SIEM

Correlaciona logs de múltiples fuentes y genera alertas automáticas



IDS/IPS

Detecta patrones de tráfico malicioso en la red en tiempo real



Usuarios

Reportes de comportamientos sospechosos por empleados o clientes



EDR / XDR

Monitoreo de endpoints con detección basada en comportamiento e IA

Preguntas clave al detectar un incidente:

?

¿Cuándo comenzó? ¿Qué sistemas están afectados?

?

¿Cuál es el impacto potencial (datos, operaciones, reputación)?

?

¿Es un falso positivo o un incidente real? ¿Qué nivel de severidad tiene?

2. DETECCIÓN Y ANÁLISIS

Los ataques son inevitables.

La detección temprana limitará el daño potencial.

Software de detección (IDS, IPS, SIEM): permite centralizar y correlacionar alertas, eventos y registros de múltiples sistemas, facilitando la detección temprana de incidentes y el análisis automatizado.

- **Alertas**, como de sistemas de detección o prevención de intrusiones (IDS o IPS), software de gestión de eventos e información de seguridad (SIEM) y aplicaciones antivirus
- **Registros** de flujos de red, registros de dispositivos de red o registros de aplicaciones, servicios o sistemas operativos
- **Información** disponible públicamente, como las noticias o la National Vulnerability Database (NVD)
- **Personas** de dentro o fuera de una organización que comunican información o comportamientos inusuales del sistema



PASO 3 — CONTENCIÓN

1
Prep.

2
Ident.

3
Conten.

4
Errad.

5
Recup.

6
Post-IR

● **Limitar el alcance y daño del incidente. El objetivo es evitar que se propague a otros sistemas mientras se trabaja en la eliminación definitiva.**

Tipos de contención:

⚡ Contención a Corto Plazo

- ▶ Desconectar el sistema afectado de la red
- ▶ Bloquear IP o cuenta comprometida
- ▶ Cambiar credenciales de acceso afectadas
- ▶ Deshabilitar servicios vulnerables temporalmente

🕒 Contención a Largo Plazo

- ▶ Aplicar parches de seguridad temporales
- ▶ Aumentar monitoreo de sistemas adyacentes
- ▶ Implementar reglas de firewall adicionales
- ▶ Preparar entorno limpio para recuperación

⚠ **La contención puede significar pérdida temporal de servicio — esto es aceptable. Lo inaceptable es dejar que el ataque se propague.**

PASO 4 — ERRADICACIÓN

1
Prep.

2
Ident.

3
Conten.

4
Errad.

5
Recup.

6
Post-IR

 **Eliminar completamente la causa raíz del incidente: malware, backdoors, vulnerabilidades explotadas y cualquier persistencia que haya dejado el atacante.**

01

Análisis forense

Recolectar y preservar evidencia: logs, capturas de memoria, imágenes de disco para análisis posterior.

02

Eliminar el malware

Usar herramientas antimalware especializadas. En casos graves, formatear y reinstalar desde cero.

03

Cerrar vulnerabilidades

Aplicar parches, corregir configuraciones incorrectas, eliminar accesos no autorizados y backdoors.

04

Verificar la limpieza

Escaneos múltiples para confirmar que el sistema está libre de amenazas antes de proceder a la recuperación.

PASO 5 — RECUPERACIÓN

1
Prep.

2
Ident.

3
Conten.

4
Errad.

5
Recup.

6
Post-IR

 **Restaurar los sistemas y servicios a su funcionamiento normal de manera segura y controlada, validando que todo opera correctamente antes de volver a producción.**



Restaurar desde backup

Usar copias de seguridad limpias verificadas para restaurar datos y sistemas afectados.



Resetear credenciales

Cambiar todas las contraseñas y tokens de las cuentas comprometidas o



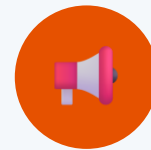
Monitoreo intensivo

Aumentar la vigilancia de los sistemas recuperados durante al menos 30 días post-



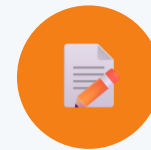
Pruebas de validación

Verificar que servicios, datos e integridad del sistema sean correctos antes de la vuelta a producción.



Comunicar el restablecimiento

Informar a usuarios, clientes y stakeholders que el servicio ha sido restaurado y es seguro.



Documentar el proceso

Registrar cada paso de la recuperación para el informe final y futuras mejoras.

PASO 6 — LECCIONES APRENDIDAS (POST-INCIDENTE)

1
Prep.

2
Ident.

3
Conten.

4
Errad.

5
Recup.

6
Post-IR

 **Analizar el incidente en retrospectiva para identificar qué falló, qué funcionó y cómo mejorar los controles, procesos y la preparación futura.**

El informe post-incidente debe responder:



¿Cuándo y cómo ocurrió el incidente?



¿Cuál fue el impacto real (datos, tiempo, costo)?



¿Qué acciones se tomaron y cuándo?



¿Qué falló en la detección o respuesta?



¿Qué controles hubieran prevenido el incidente?



¿Qué mejoras se implementarán?



Las lecciones aprendidas alimentan la fase de Preparación — cerrando el ciclo de mejora continua.

on with



02

HERRAMIENTAS CLAVE DE RESPUESTAS ANTE INCIDENTES

*DETECCIÓN, CONTENCIÓN, ERRADICACIÓN,
RECUPERACIÓN*



HERRAMIENTAS CLAVE DE RESPUESTA ANTE INCIDENTES



SIEM

Security Information & Event Management

Centraliza y correlaciona logs de toda la infraestructura. Genera alertas automáticas cuando detecta patrones anómalos.

IBM QRadar · Microsoft Sentinel · Splunk · Elastic SIEM



IDS / IPS

Intrusion Detection/Prevention System

Monitorea el tráfico de red en tiempo real. IDS alerta; IPS bloquea activamente el tráfico malicioso.

Snort · Suricata · Zeek · Palo Alto NGFW



EDR / XDR

Endpoint/Extended Detection & Response

Monitorea todos los endpoints (PCs, servidores) con análisis de comportamiento e IA para detectar amenazas avanzadas.

CrowdStrike Falcon · Microsoft Defender for Endpoint · SentinelOne



Análisis Forense

Digital Forensics Tools

Permiten recolectar, preservar y analizar evidencia digital sin alterar su integridad para investigación y procesos legales.

Autopsy · FTK · Volatility (memoria) · Wireshark



Ticketing IR

Sistema de Gestión de Incidentes

Documenta y rastrea cada acción tomada durante el incidente, asegurando trazabilidad completa del proceso de respuesta.

TheHive · Jira · ServiceNow · PagerDuty



Threat Intelligence

Inteligencia de Amenazas

Proporciona contexto sobre amenazas actuales: IOCs, TTPs de atacantes y feeds de vulnerabilidades en tiempo real.

MISP · VirusTotal · IBM X-Force · MITRE ATT&CK

A network diagram with nodes and connecting lines, located in the top-left corner of the slide.

03

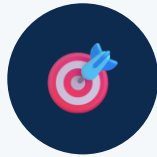
ROLES Y EQUIPO DE RESPUESTA

Roles y Equipo de Respuesta (CSIRT)



EQUIPO DE RESPUESTA (CSIRT) – ROLES Y FUNCIONES

CSIRT – Computer Security Incident Response Team: grupo multidisciplinar responsable de gestionar incidentes de seguridad de principio a fin.



Líder de IR

Coordina toda la respuesta, toma decisiones críticas y gestiona comunicaciones con dirección.



Analista de Seguridad

Investiga alertas, analiza logs y determina el alcance del incidente.



Especialista Forense

Recolecta evidencia digital preservando la cadena de custodia para posibles acciones legales.



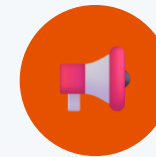
Especialista de Red

Gestiona el aislamiento de sistemas y analiza tráfico de red sospechoso.



Asesor Legal / Compliance

Asegura que la respuesta cumpla la normativa (GDPR, NIS2) y gestiona notificaciones legales.

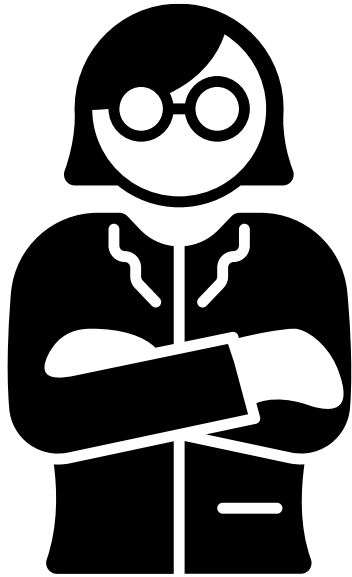


Comunicaciones

Gestiona mensajes a clientes, empleados, medios y reguladores durante y post-incidente.

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

EQUIPO DE RESPUESTA A INCIDENTES



Una sola persona en la organización, el **jefe del equipo**, debe ser responsable de llevar a cabo el plan de respuesta a incidentes (IRP)



El líder técnico es alguien con sólidas habilidades técnicas y experiencia en respuesta a incidentes que dirige el trabajo técnico del equipo y asume la responsabilidad final del mismo.

En determinadas circunstancias, los equipos más grandes pueden asignar un **líder de incidentes** como punto de contacto principal para manejar un incidente específico.

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

EQUIPO DE RESPUESTA A INCIDENTES

Cada equipo de respuesta a incidentes (depende de la experiencia, el juicio y las habilidades de otros.

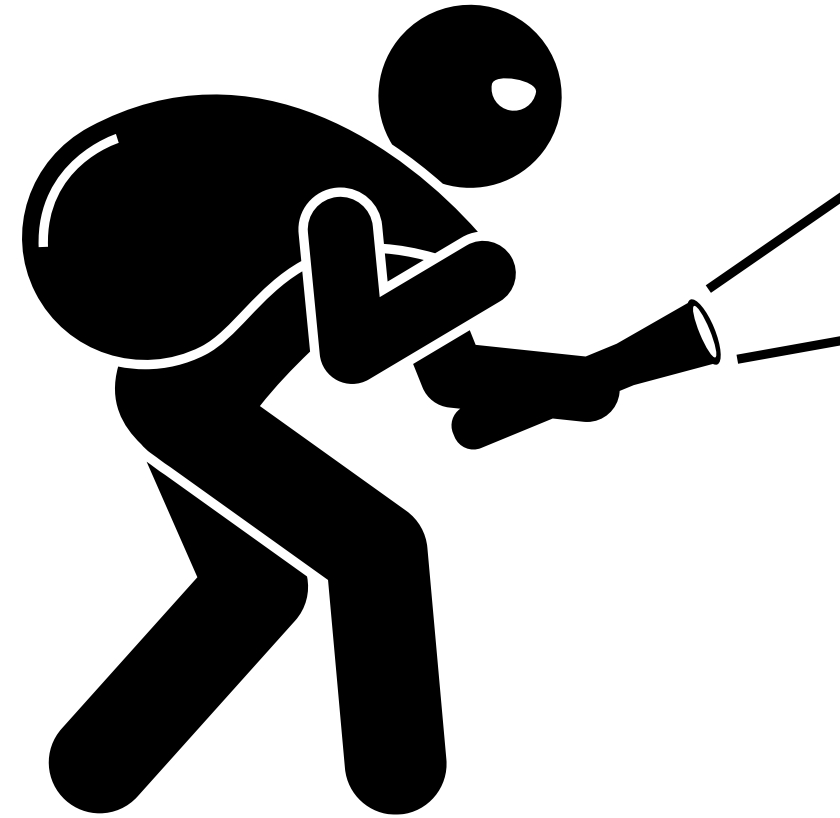
El IRP debe asociarse con otros grupos relevantes de la organización para que los miembros del equipo puedan entender cómo pueden ayudar y los otros grupos sepan cuándo contactarlos.



A network diagram consisting of several grey dots connected by thin grey lines, forming a web-like structure in the top-left corner of the slide.

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

El análisis de intrusiones y el proceso de recopilación e interpretación de información sobre un ataque para que el equipo de respuesta a incidentes ayuden a obtener una respuesta eficaz frente al ataque



RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

EQUIPO DE RESPUESTA A INCIDENTES

El análisis de intrusiones es el proceso de emplear información sobre un ataque para determinar el alcance del ataque, el método empleado por el atacante para obtener acceso y el alcance del daño al sistema o la red.

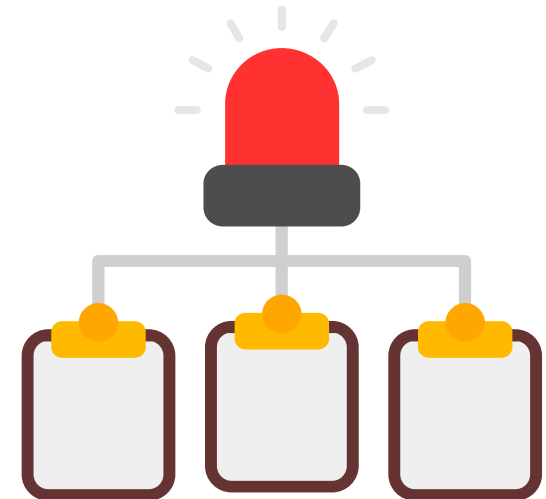
Áreas clave del análisis de intrusiones

Adversario

Infraestructura

Capacidad

Objetivo



RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

QUÉ ES EL ANÁLISIS DE INTRUSIONES

El análisis de intrusiones es el proceso de emplear información sobre un ataque para:

- determinar el **alcance del ataque**
- el **método** empleado por el atacante para obtener acceso
- y el **alcance del daño** al sistema o la red.

ÁREAS

Adversario

Capacidad

Infraestructura

Objetivo





04

MITRE ATT&CK

MITRE ATT&CK



MARCO DE ANÁLISIS DE INTRUSIONES

Un marco de análisis de intrusiones es una herramienta que describe las tácticas, estrategias y objetivos típicos de los atacantes.

La elección de un marco establecido proporciona al equipo de IR un punto de partida sólido para comprender lo que se pretende lograr con los ataques.

2 marcos populares y efectivos para el análisis de intrusiones:

- **Marco MITRE ATT&CK**
- **Marco Cyber Kill Chain**

MARCO MITRE ATT&CK



- **Recurso** para analizar intrusiones y entender el comportamiento de los atacantes.
- Basado en **observaciones** reales, muestra cómo acceden, qué herramientas usan y qué pasos siguen.
- Utilizado por analistas e IR para **evaluar** la postura de seguridad y compartir buenas prácticas.
- Su **matriz** organiza tácticas desde el reconocimiento hasta el impacto final (el orden puede variar)

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

MARCO MITRE ATT&CK



RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

MARCO CYBER KILL CHAIN

- Herramienta útil para identificar, entender y responder a intrusiones, similar a MITRE ATT&CK
- Se enfoca en los objetivos del atacante, no en las técnicas específicas
- Propone una secuencia fija de pasos: si el atacante no la sigue, el ataque falla
- A diferencia de MITRE ATT&CK, que es más flexible y centrado en las técnicas utilizadas



RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

MARCO CYBER KILL CHAIN





MITRE

ATT&CKTM

¿Qué es MITRE ATT&CK?

TTPs

¿Qué es MITRE ATT&CK?

Tácticas

Técnicas

Procedimientos

Reconnaissance 10 techniques	Resource Development 8 techniques	Initial Access 9 techniques	Execution 14 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 42 techniques	Credential Access 17 techniques	Discovery 31 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 16 techniques	Exfiltration 9 techniques	Impact 13 techniques
Active Scanning (0/3)	Acquire Access	Drive-by Compromise	Cloud Administration Command	Account Manipulation (0/5)	Abuse Elevation Control Mechanism (0/4)	Abuse Elevation Control Mechanism (0/4)	Adversary-in-the-Middle (0/3)	Account Discovery (0/4)	Exploitation of Remote Services	Adversary-in-the-Middle (0/3)	Application Layer Protocol (0/4)	Automated Exfiltration (0/1)	Account Access Removal
Gather Victim Host Information (0/4)	Acquire Infrastructure (0/8)	Exploit Public-Facing Application	Command and Scripting Interpreter (0/9)	BITS Jobs	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (0/4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (0/3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
Gather Victim Identity Information (0/3)	Compromise Accounts (0/3)	External Remote Services	Container Administration Command	Boot or Logon Autostart Execution (0/14)	Boot or Logon Autostart Execution (0/14)	BITS Jobs	Credentials from Password Stores (0/5)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Data Encoding (0/2)	Exfiltration Over Alternative Protocol (0/3)	Data Encrypted for Impact
Gather Victim Network Information (0/6)	Compromise Infrastructure (0/7)	Hardware Additions	Deploy Container	Boot or Logon Initialization Scripts (0/5)	Boot or Logon Initialization Scripts (0/5)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (0/2)	Automated Collection	Data Obfuscation (0/3)	Exfiltration Over C2 Channel	Data Manipulation (0/3)
Gather Victim Org Information (0/4)	Develop Capabilities (0/4)	Phishing (0/3)	Exploitation for Client Execution	Browser Extensions	Create or Modify System Process (0/4)	Deobfuscate/Decode Files or Information	Forced Authentication	Cloud Service Dashboard	Remote Services (0/7)	Browser Session Hijacking	Dynamic Resolution (0/3)	Exfiltration Over Other Network Medium (0/1)	Defacement (0/2)
Phishing for Information (0/3)	Establish Accounts (0/3)	Replication Through Removable Media	Inter-Process Communication (0/3)	Compromise Client Software Binary	Domain Policy Modification (0/2)	Deploy Container	Forge Web Credentials (0/2)	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Encrypted Channel (0/2)	Exfiltration Over Physical Medium (0/1)	Disk Wipe (0/2)
Search Closed Sources (0/2)	Obtain Capabilities (0/6)	Supply Chain Compromise (0/3)	Native API	Create Account (0/3)	Escape to Host	Direct Volume Access	Input Capture (0/4)	Container and Resource Discovery	Data from Cloud Storage	Data from Configuration Repository (0/2)	Fallback Channels	Ingress Tool Transfer	Endpoint Denial of Service (0/4)
Search Open Technical Databases (0/5)	Stage Capabilities (0/6)	Trusted Relationship	Scheduled Task/Job (0/5)	Create or Modify System Process (0/4)	Event Triggered Execution (0/16)	Execution Guardrails (0/1)	Modify Authentication Process (0/8)	Debugger Evasion	Data from Information Repositories (0/3)	Data from Local System	Multi-Stage Channels	Non-Application Layer Protocol	Firmware Corruption
Search Open Websites/Domains (0/3)		Valid Accounts (0/4)	Serverless Execution	Event Triggered Execution (0/16)	Exploitation for Privilege Escalation	Exploitation for Defense Evasion	Multi-Factor Authentication Interception	Device Driver Discovery	Data from Network Shared Drive	Data from Removable Media	Non-Standard Port	Protocol Tunneling	Inhibit System Recovery
Search Victim-Owned Websites			Shared Modules	Hijack Execution Flow (0/12)	Hijack Execution Flow (0/12)	File and Directory Permissions Modification (0/2)	Multi-Factor Authentication Request Generation	Domain Trust Discovery	Data Staged (0/2)	Email Collection (0/3)	Proxy (0/4)	Remote Access Software	Network Denial of Service (0/2)
			Software Deployment Tools	Implant Internal Image	Scheduled Task/Job (0/5)	Hide Artifacts (0/10)	Network Sniffing	File and Directory Discovery	Input Capture (0/4)	Screen Capture	Traffic Signaling (0/2)	Scheduled Transfer	Resource Hijacking
			System Services (0/2)	Modify Authentication Process (0/8)	Office Application Startup (0/6)	Hijack Execution Flow (0/12)	OS Credential Dumping (0/8)	Group Policy Discovery	Use Alternate Authentication Material (0/4)		Web Service (0/3)	Transfer Data to Cloud Account	Service Stop
			User Execution (0/3)	Pre-OS Boot (0/5)		Impair Defenses (0/10)	Steal Application Access Token	Network Service Discovery					System Shutdown/Reboot
			Windows Management Instrumentation			Indicator Removal (0/9)	Steal or Forge Authentication Certificates	Network Share Discovery					
						Indirect Command Execution		Password Policy Discovery					
						Masquerading (0/8)		Peripheral Device Discovery					
						Modify Authentication Process		Permission Groups					

Técnicas

Tácticas

SkillUp

In collaboration with
IBM SkillsBuild

MITRE ATT&CK — ¿Qué es y para qué sirve?

El framework más usado en la industria para describir comportamiento adversarial

MITRE ATT&CK (Adversarial Tactics, Techniques & Common Knowledge) es una base de conocimiento pública y gratuita que documenta las técnicas reales que usan los atacantes, basadas en incidentes observados en el mundo real.

TÁCTICAS (14)

El **OBJETIVO** del atacante en esa fase.
¿Qué quiere lograr ahora?

Ejemplo: 'Persistencia'
→ quiere quedarse en el sistema aunque lo reinicien.

TÉCNICAS (+200)

El **CÓMO** logra ese objetivo.
Cada técnica tiene un código T-XXXX.

Ejemplo: T1053.005
→ Scheduled Task para persistir.

PROCEDIMIENTOS

La implementación **ESPECÍFICA** de la técnica por un actor concreto.

Ejemplo: APT29 usa PowerShell para crear la tarea programada.

Acceso libre y gratuito en attack.mitre.org · Estándar de facto en la industria CTI global

EC-COUNCIL CERTIFIED INCIDENT HANDLER (CIH)

EC-Council ofrece la certificación Certified Incident Handler (CIH) que ayuda a los profesionales de ciberseguridad a prepararse para gestionar incidentes de ciberseguridad y responder a ellos.

La certificación CIH cubre lo siguiente:

- Incidentes de malware
- Incidentes de seguridad en la nube
- Incidentes de seguridad del correo electrónico
- Incidentes de seguridad de aplicaciones web
- Incidentes de seguridad de la red
- Amenazas internas



05

SIMULACIÓN DE CIBERATAQUE

CREACIÓN DE INFORME DE RESPUESTA

SkillUp

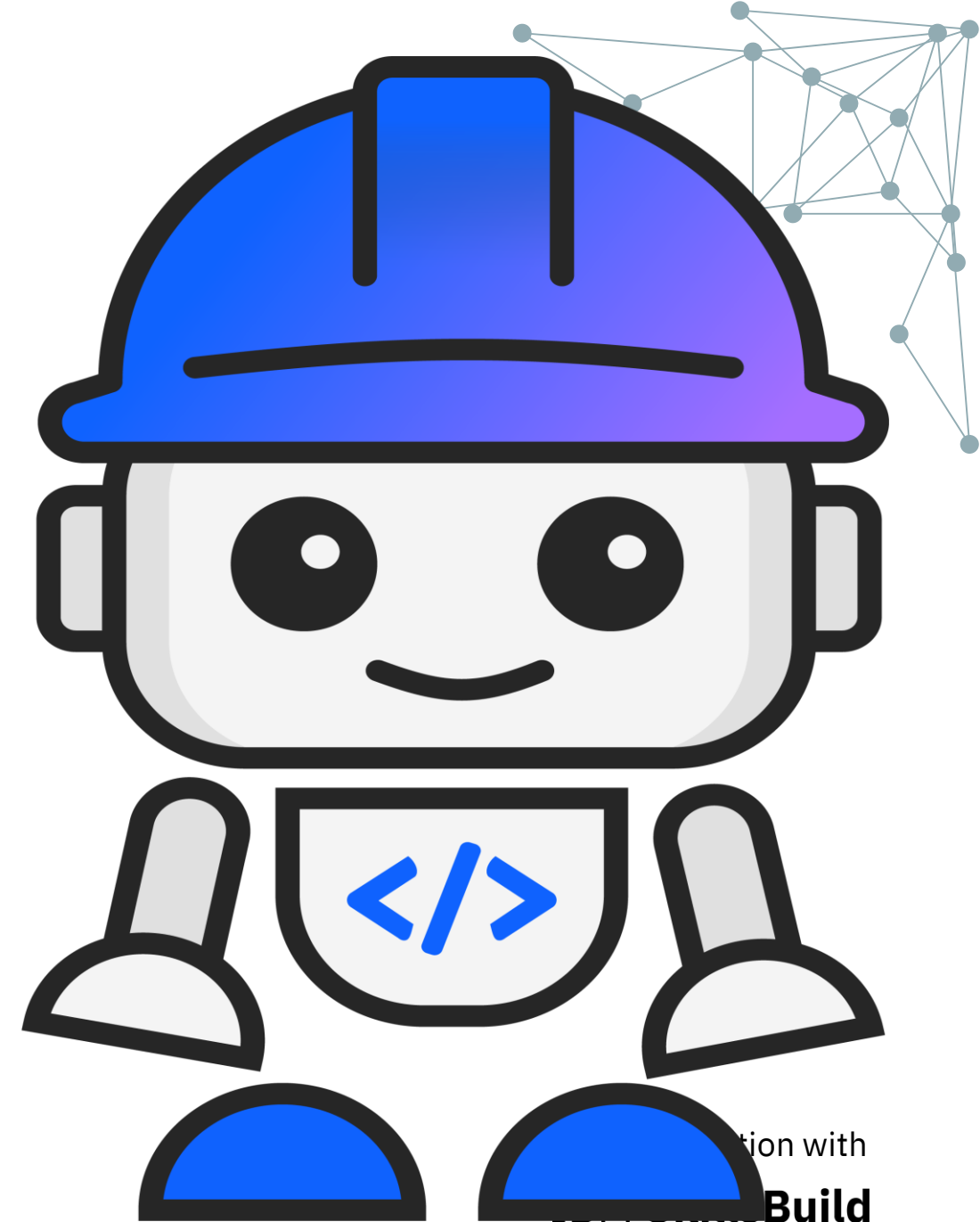


In collaboration with
IBM SkillsBuild

De herramientas de IA a sistemas de entrega

*Más allá de la generación de código hacia resultados
empresariales reales*

SkillUp **IBM**



tion with
Build

2025 demostró que la IA redefinió cómo se construye software, preparando el terreno para un

nuevo modelo de entrega empresarial.

Lo que 2025 nos enseñó...

- La IA aumentó el rendimiento individual del desarrollador
- La seguridad y gobernanza debieron mantenerse al ritmo
- La IA mejoró la comprensión y modernización del código
- Las herramientas permanecieron en gran medida aisladas

...y lo que los sistemas deben incorporar

- ✓ Optimizar la productividad de entrega organizacional
- ✓ Integrar seguridad y gobernanza en todo el SDLC
- ✓ Incorporar contexto arquitectónico y operacional
- ✓ Gestionar costos y consumo de recursos

SkillUp



In collaboration with
IBM SkillsBuild

Próximos pasos

¡Prueba Bob gratis!



Aprendices del Webinar

Regístrate para el trial →
<https://ibm.biz/bobtrialwebinar>



Aprendices del Cohorte

Regístrate para el trial →
<https://ibm.biz/bobtrialcohort>

Ver Bob en acción

- Tu socio de codificación agéntica →
- Modernización Java →
- Despliega con confianza →
- De la observabilidad a la acción →
- Modernización en IBM i →

Seguir a Bob en YouTube

→ Bob YouTube →

Canal oficial de IBM Bob con demostraciones, tutoriales y casos de uso reales



IBM SkillsBuild

EJERCICIO — CREAR UNA REGLA YARA CON IBM BOB



CASO: El equipo forense analizó un archivo malicioso detectado en un endpoint hospitalario.

Encontraron los siguientes indicadores. Tu misión: usarlos para que Bob genere una regla YARA que detecte este malware en otros sistemas.

Indicadores del archivo sospechoso

Nombre	factura_mayo.pdf.exe
MD5	a3f2c1d8e9b04f7a6c5d2e1f8
SHA256	7f3a8c2d1e9b04f6a5c3d2e1f8a7b6c5 d4e3f2a1b8c7d6e5f4a3b2c1d0e9f8a7
Tamaño	91.204 bytes
Tipo	PE32 executable (GUI) Intel 80386
Sección	.text entropy: 7.82 (alta — posible cifrado)

Strings y comportamiento observado

```
strings factura_mayo.pdf.exe | grep -i interesante

cmd.exe /c powershell.exe -Enc
vssadmin delete shadows /all
185.220.101.143
/update.php?id=
DECRYPT_YOUR_FILES.txt
AES_encrypt_file
generate_ransom_key
Mozilla/5.0 (compatible; bot)
SOFTWARE\Microsoft\Windows\CurrentVersion\Run
```

Comportamiento detectado:

Crea mutex • Contacta C2 vía HTTP • Escanea unidades de red
Cifra con AES-256 • Elimina shadow copies • Persiste en Run key



Prompt para Bob: «Con estos indicadores crea una regla YARA completa que detecte este ransomware. Incluye condiciones para los strings, el hash, el tamaño y la entropía de la sección .text. Agrega comentarios explicando cada condición.»

File Edit Selection View Go ... < > Search

EXPLORER ...

NO FOLDER OPENED

You have not yet opened a folder.

Open Folder

Opening a folder will close all currently open editors. To keep them open, add a folder instead.

Untitled-1 X

1 *Select a Language (Ctrl+K M) to get started. Start typing to dismiss or don't show this again.*

IBM BOB

Auto-approval disabled

Con estos indicadores crea una regla YARA completa que detecte este ransomware. Incluye condiciones para los strings, el hash, el tamaño y la entropía de la sección .text. Agrega comentarios explicando cada condición.

Nombre : factura_mayo.pdf.exe
MD5 : a3f2c1d8e9b04f7a6c5d2e1f8a9b3c4d
SHA256 : 7f3a8c2d1e9b04f6a5c3d2e1f8a7b6c5d4e3f2a1b8c7d6e5f4a3b2c1d0e9f8a7
Tamaño : 91.204 bytes
Tipo : PE32 executable (GUI) Intel 80386
Sección : .text entropy: 7.82 (alta — posible cifrado/packing)

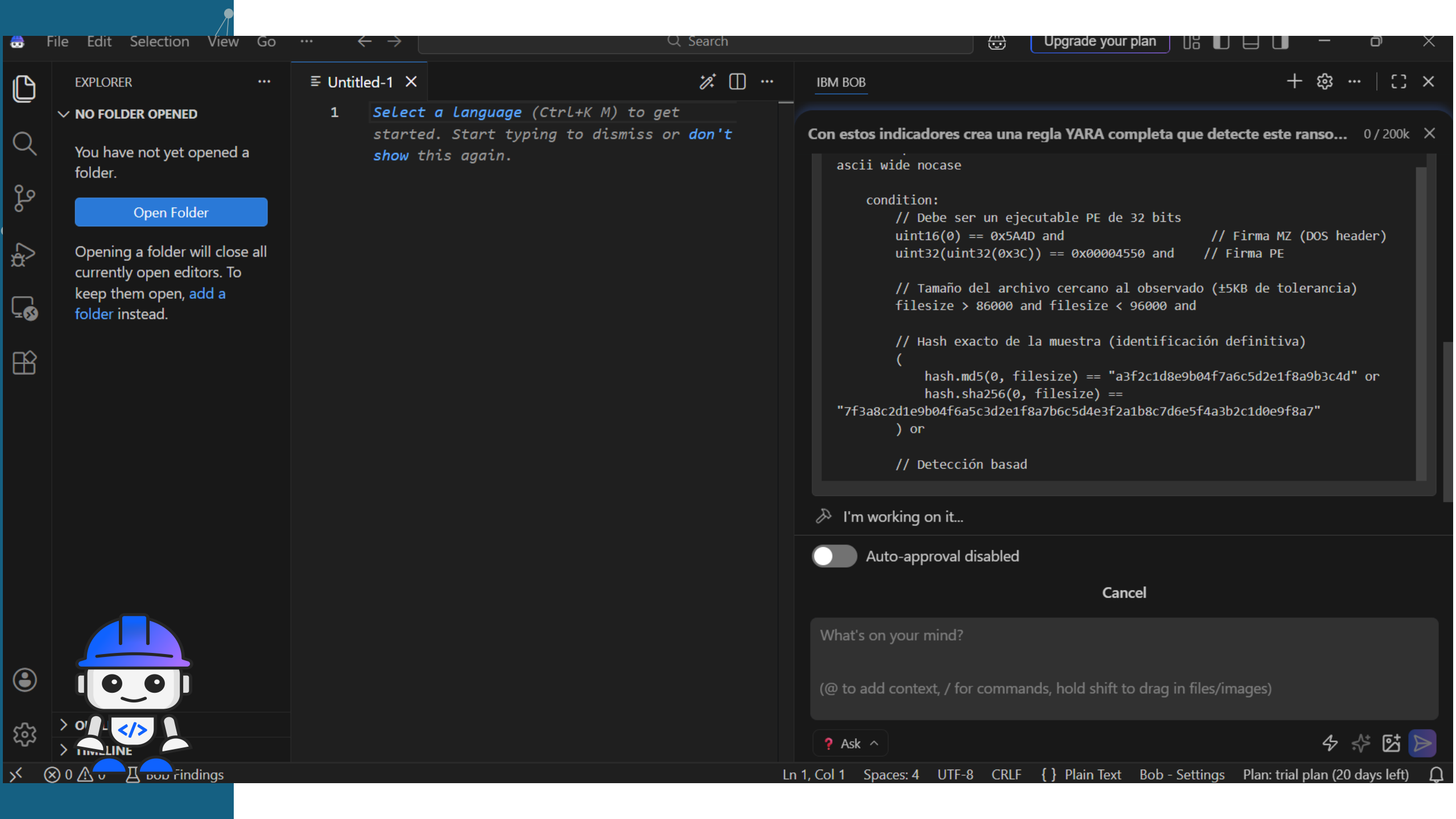
STRINGS EXTRAÍDOS

cmd.exe /c powershell.exe -Enc

Ask

< 0 0 Bob Findings

In 1, Col 1 Spaces: 4 UTF-8 CRLF { } Plain Text Bob - Settings Plan: trial plan (20 days left)



EXPLORER

NO FOLDER OPENED

You have not yet opened a folder.

Open Folder

Opening a folder will close all currently open editors. To keep them open, add a folder instead.

Untitled-1

```
1 Select a Language (Ctrl+K M) to get started. Start typing to dismiss or don't show this again.
```

IBM BOB

Con estos indicadores crea una regla YARA completa que detecte este ranso... 0 / 200k

```
ascii wide nocase

condition:
    // Debe ser un ejecutable PE de 32 bits
    uint16(0) == 0x5A4D and // Firma MZ (DOS header)
    uint32(uint32(0x3C)) == 0x00004550 and // Firma PE

    // Tamaño del archivo cercano al observado (±5KB de tolerancia)
    filesize > 86000 and filesize < 96000 and

    // Hash exacto de la muestra (identificación definitiva)
    (
        hash.md5(0, filesize) == "a3f2c1d8e9b04f7a6c5d2e1f8a9b3c4d" or
        hash.sha256(0, filesize) ==
        "7f3a8c2d1e9b04f6a5c3d2e1f8a7b6c5d4e3f2a1b8c7d6e5f4a3b2c1d0e9f8a7"
    ) or

    // Detección basad
```

I'm working on it...

Auto-approval disabled

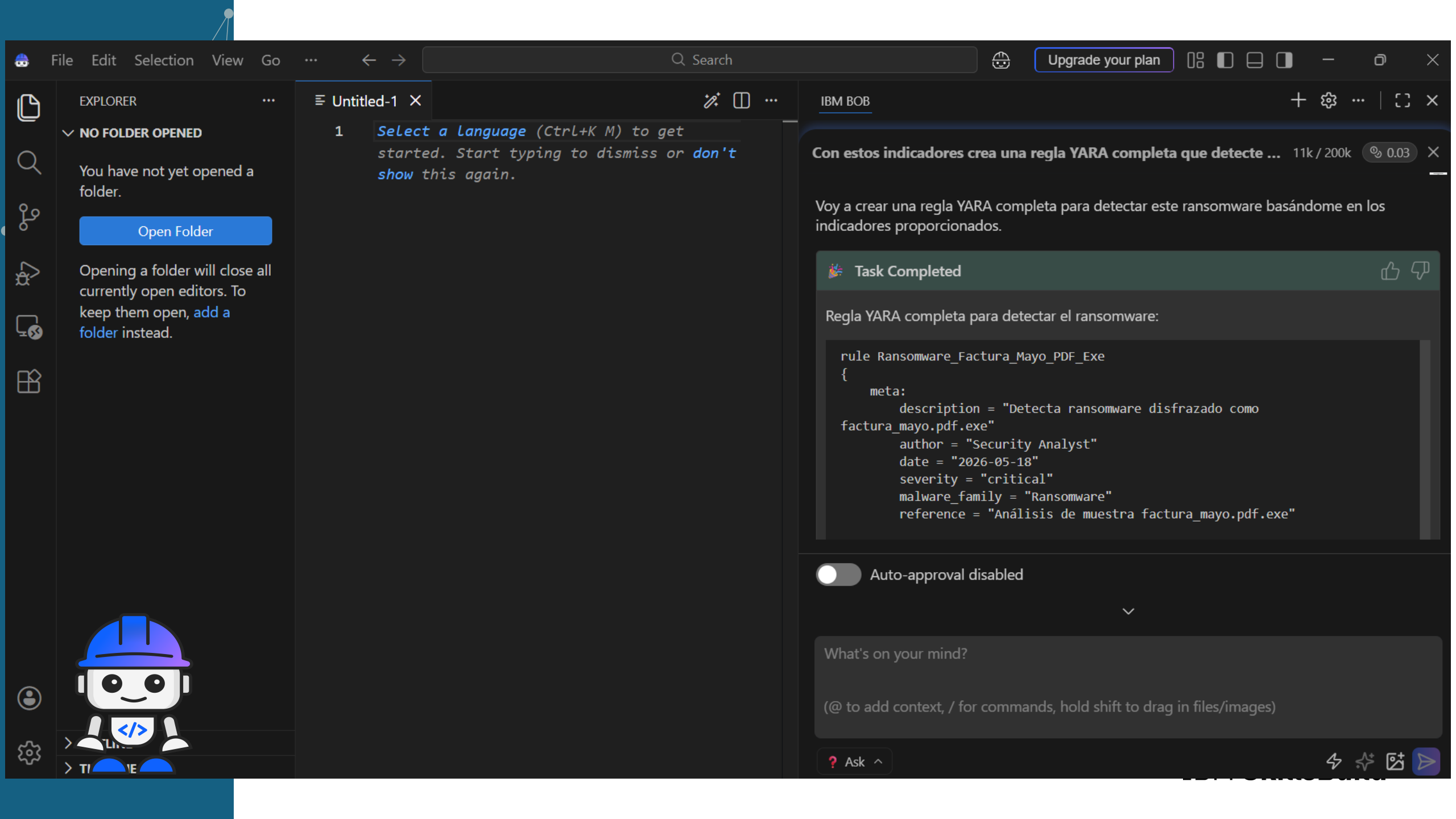
Cancel

What's on your mind?

(@ to add context, / for commands, hold shift to drag in files/images)

Ask





EXPLORER

NO FOLDER OPENED

You have not yet opened a folder.

Open Folder

Opening a folder will close all currently open editors. To keep them open, add a folder instead.

Untitled-1

1 Select a Language (Ctrl+K M) to get started. Start typing to dismiss or don't show this again.

IBM BOB

Con estos indicadores crea una regla YARA completa que detecte ... 11k / 200k 0.03

Voy a crear una regla YARA completa para detectar este ransomware basándome en los indicadores proporcionados.

Task Completed

Regla YARA completa para detectar el ransomware:

```
rule Ransomware_Factura_Mayo_PDF_Exe
{
  meta:
    description = "Detecta ransomware disfrazado como factura_mayo.pdf.exe"
    author = "Security Analyst"
    date = "2026-05-18"
    severity = "critical"
    malware_family = "Ransomware"
    reference = "Análisis de muestra factura_mayo.pdf.exe"
```

Auto-approval disabled

What's on your mind?

(@ to add context, / for commands, hold shift to drag in files/images)

Ask

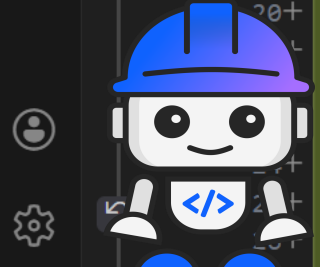
Untitled-1

Untitled-1

Untitled-1: New File (Editable)

C:\> Users > ingms > AppData > Local > Programs > IBM Bob > Untitled-1

```
1 -
1+ rule Ransomware_Factura_Mayo_PDF_Exe {
2+     meta:
3+         description = "Detecta ransomware disfrazado como factura_mayo.pdf.
4+         exe"
5+         author = "Security Analyst"
6+         date = "2026-05-18"
7+         hash_md5 = "a3f2c1d8e9b04f7a6c5d2e1f8a9b3c4d"
8+         hash_sha256 =
9+         "7f3a8c2d1e9b04f6a5c3d2e1f8a7b6c5d4e3f2a1b8c7d6e5f4a3b2c1d0e9f8a7"
10+         severity = "critical"
11+         malware_type = "ransomware"
12+
13+     strings:
14+         // Comandos de eliminación de backups y shadow copies
15+         $cmd1 = "vssadmin delete shadows /all" ascii wide nocase
16+         $cmd2 = "wbadmin delete catalog" ascii wide nocase
17+         $cmd3 = "cmd.exe /c powershell.exe -Enc" ascii wide nocase
18+
19+         // Infraestructura C2
20+         $c2_ip = "185.220.101.143" ascii wide
21+         $c2_endpoint = "/update.php?id=" ascii wide
22+
23+         // Indicadores de cifrado y nota de rescate
24+         $ransom_note = "DECRYPT_YOUR_FILES.txt" ascii wide nocase
25+         $aes_func = "AES_encrypt_file" ascii wide
26+         $key_gen = "generate_ransom_key" ascii wide
27+
28+         // Persistencia en registro
```



IBM BOB

Con estos indicadores crea una regla YARA compl... 6k / 200k 0.07

Esta regla balancea especificidad (para evitar falsos positivos) con flexibilidad (para detectar variantes del mismo ransomware).

crea el archivo dentro de aqui en el file ultitled-1

Entiendo que necesitas que cambie al modo Code para crear el archivo. Permíteme hacer eso.

I want to switch to code mode because: Necesito crear el archivo YARA en Untitled-1 según la solicitud del usuario

Ahora voy a crear el archivo YARA en el archivo Untitled-1.

I want to create a new file:

C:/Users/ingms/AppData/Local/Programs/IBM Bob/Untitled-1

Auto-approval disabled

Save Reject

What's on your mind?

(@ to add context, / for commands, hold shift to drag in files/images)

Code

SIMULACIÓN DE UN CIBERATAQUE – SILVERHEDGE FINANCIAL



RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

SIMULACIÓN DE UN CIBERATAQUE – SILVERHEDGE FINANCIAL

SilverHedge Financial, una empresa de servicios financieros, se preparó para una posible violación de seguridad implantando medidas de seguridad, como firewalls, sistemas de detección de intrusiones y controles de acceso.

Su equipo de seguridad **detectó una actividad inusual en la red**, como varios intentos fallidos de inicio de sesión, un rendimiento lento del sistema, una actividad inusual de archivos y un tráfico de red sospechoso.

El equipo **activó inmediatamente el plan de respuesta** a incidentes e inició una investigación para determinar el alcance y el impacto del incidente.

SIMULACIÓN DE UN CIBERATAQUE – SILVERHEDGE FINANCIAL



- Tipo de ataque: Fuerza bruta contra cuentas de usuario (login repetido con contraseñas comunes)
- Escenario: Un atacante externo lanza miles de intentos de acceso remoto al sistema corporativo usando credenciales de inicio de sesión
- Objetivo del atacante: Obtener acceso a cuentas privilegiadas en el servidor expuesto

SIMULACIÓN DE UN CIBERATAQUE – SILVERHEDGE FINANCIAL

Respuesta simulada

- Identificación: El sistema IDS/IPS detecta múltiples intentos de login fallidos en poco tiempo.
- Contención: Se bloquea la IP atacante desde el firewall.
- Erradicación: Se revisan los sistemas afectados, no se detecta intrusión exitosa.
- Recuperación: Se refuerzan contraseñas y se activa MFA (Autenticación Multifactor)

IDS	<i>Intrusion Detection System</i>	Detecta actividad sospechosa o maliciosa en la red o sistemas.
IPS	<i>Intrusion Prevention System</i>	Detecta y bloquea automáticamente comportamientos maliciosos.
SIEM	<i>Security Information and Event Management</i>	Recoge y analiza registros (logs) de toda la red para detectar patrones anómalos.

SIMULACIÓN DE UN CIBERATAQUE – SILVERHEDGE FINANCIAL

INFORME DE RESPUESTA A INCIDENTES

	Nombre del incidente:	Intento de intrusión mediante fuerza bruta
	Fecha del incidente:	[Especificar]
	Organización:	SilverHedge Financial
	Redactor del informe:	[Tu nombre o rol]
	Fecha del informe:	[Especificar]
	Ciclo NIST de IR	
	1. Resumen ejecutivo	Proceso de gestión de incidentes de seguridad

El [día/fecha], se detectó actividad sospechosa consistente con un ataque de fuerza bruta dirigido al sistema de autenticación de la red corporativa. Gracias a las medidas de monitoreo activas, se identificó el intento a tiempo y se activó el protocolo de respuesta a incidentes. No se produjo acceso no autorizado ni fuga de datos.



In collaboration with
IBM SkillsBuild

RESPUESTA A INCIDENTES Y SIMULACIÓN DE CIBERATAQUES

SIMULACIÓN DE UN CIBERATAQUE – SILVERHEDGE FINANCIAL

3. Contención, Erradicación y Recuperación

Contención: aislamiento de máquinas infectadas

Erradicación: eliminación del malware

Recuperación: restauración de sistemas con backups, aplicación de parches y actualizaciones y verificación de la seguridad de la red

CONCLUSIONES DEL INFORME

Revisión post-incidente para detectar mejoras

Notificación a clientes y socios

Compromiso con medidas correctivas de protección de datos



INFORME DE RESPUESTA A INCIDENTES

1. Preparación

- Firewalls, IDS y controles de acceso implementados.
- Plan de respuesta a incidentes establecido.
- Concienciación básica en seguridad (aunque falló en el phishing)

2. Detección y Análisis

- Señales detectadas
 - Intentos fallidos de login
 - Rendimiento lento
 - Actividad inusual de archivos
 - Tráfico sospechoso
- Investigación activada para determinar el origen
 - Correo de phishing con malware
 - Identificación del alcance y del acceso a datos confidenciales



ESCENARIO: ATAQUE DE FUERZA BRUTA SSH

ESCENARIO

El SIEM genera una alerta: 500 intentos fallidos de login SSH en 2 minutos desde la IP 185.234.x.x hacia el servidor de producción web-01. Un analista debe activar el protocolo de respuesta.

Respuesta paso a paso:

IDENTIFICAR

- Verificar la alerta en el SIEM
- Revisar logs de /var/log/auth.log
- Confirmar que es un ataque real (no un administrador)

CONTENER

- Bloquear IP atacante en firewall: iptables -A INPUT -s 185.234.x.x -j DROP
- Deshabilitar temporalmente el acceso SSH público
- Notificar al líder del CSIRT

ERRADICAR

- Verificar si hay cuentas comprometidas o backdoors creados
- Revisar últimos logins exitosos (last, lastb)
- Cambiar contraseñas de todas las cuentas del sistema

RECUPERAR

- Configurar autenticación por clave SSH (deshabilitar contraseñas)
- Implementar fail2ban para bloqueo automático
- Restablecer acceso seguro y verificar integridad del servidor

🎯 Objetivo: crear el informe post-incidente documentando cada acción, timestamp y decisión tomada.

PLANTILLA: INFORME POST-INCIDENTE

Todo incidente debe documentarse en un informe formal. A continuación la estructura estándar:

1 Resumen ejecutivo

Fecha y hora de detección · Duración total del incidente
Sistemas afectados · Impacto general (datos/servicio/reputación)

2 Cronología del incidente

HH:MM — Primera alerta detectada · HH:MM — Confirmación del incidente
HH:MM — Activación del CSIRT · HH:MM — Contención completada · HH:MM — Sistemas restaurados

3 Análisis de causa raíz

Vulnerabilidad explotada · Vector de ataque inicial
Cómo se propagó el incidente · Por qué no se detectó antes

4 Acciones tomadas

Medidas de contención aplicadas · Herramientas utilizadas
Decisiones críticas y su justificación · Partes notificadas

5 Lecciones y mejoras

Controles que fallaron · Mejoras propuestas (técnicas/procesales)
Responsable de cada mejora · Fecha límite de implementación



Enlace de retroalimentación

<https://survey.zohopublic.in/zs/UDUeV?lang=es>



Copyright Skill-Up technologies, All rights reserved . Submitted for evaluation purpose only as per existing NDA

SkillUp

In collaboration with
IBM **SkillsBuild**



¡Gracias!

Si tenés alguna pregunta adicional,
envianos un correo electrónico a:
ibmskillsbuild.eu@skillup.online

